RBAC Design Document

Backstage Role-Based Access Control — Strategy & Permission Matrix

This document defines the role-based access control strategy for the Backstage Internal Developer Platform.

Overview

Security Philosophy

- Least privilege by default: Everyone starts with the minimum access required for their role.
- **Open visibility, controlled writes:** All teams can view all APIs (to promote reuse), but can only modify what they own.
- **Protect critical areas:** Production deployments, platform templates, and Backstage configuration are restricted to specific roles.
- **Developer experience matters:** Avoid unnecessary friction, security should feel invisible when used correctly.

Role Definitions

Role	Who	Key Permissions	Key Restrictions
Developer	Developers, junior–mid engineers	View catalog, read docs, run templates, Dev/QA deployments for own APIs	No prod deployments, no template edits, no platform config
Tech Lead	Senior engineers, team tech leads	Developer permissions + modify team catalog, staging deployments, view all security scans	No prod deployments, no templates, no platform config
Platform Engineer	IDP / platform team	Full Backstage config, create/modify templates, plugin management, onboard teams	Cannot deploy MuleSoft APIs to any CloudHub env
DevOps / SRE	Operations team	Production CloudHub deployments, all pipeline management, Anypoint configs	Cannot modify Backstage platform or templates
Admin	Break-glass only	Full access to everything, all environments, all configurations	Intended for emergencies only — all actions audited

Three Critical Lockdowns

Production CloudHub Deployments: DevOps/SRE and Admin only

Scaffolder Template Modification: Platform Engineers and Admin only

Backstage Platform Configuration: Platform Engineers and Admin only

Role Consolidation Options

The five-role model represents enterprise best practice and should be the default for large organizations. Limited consolidation may be considered in specific scenarios:

- **Platform Engineer + Admin → "Platform Administrator"**
  - **When:** Small or centralized platform teams handling both operations and escalations
  - **Trade-off:** Reduces separation between routine and emergency (break-glass) access; lowers audit granularity
  - **Mitigation:** Enforce approval workflows and strong audit controls
- **Developer + DevOps/SRE → "Full-Stack Engineer"**
  - **When:** Teams operating under a mature DevOps model with shared ownership
  - **Trade-off:** Reduces separation of duties; expands production access to developers
  - **Mitigation:** Maintain deployment approvals and strict audit logging

Permission Matrix

The matrix below defines permissions for all five roles across every major Backstage feature. Use this as the definitive reference when designing integrations or reviewing access.

Feature / Permission	Developer	Tech Lead	Platform Eng	DevOps / SRE	Admin
Legend: ✕ None ◎ Read-only ✎ Write (includes Read) 🔧 Admin (full control) ** = Own team's resources only*					
SOFTWARE CATALOG					
View all catalog entries	◎	◎	◎	◎	🔧
Create catalog entries (own team)	✎	✎	✎	◎	🔧
Modify any catalog entry	✕	✎*	✎	◎	🔧
Delete catalog entries	✕	✕	🔧	✕	🔧
Docusaurus/ DOCUMENTATION					
Read all documentation	◎	◎	◎	◎	🔧
Publish docs (own team)	✎	✎	✎	◎	🔧
Publish docs (any team)	✕	✕	✎	✕	🔧
Manage Docusaurus platform config	✕	✕	🔧	✕	🔧
SCAFFOLDER / TEMPLATES					
View available templates	◎	◎	◎	◎	🔧
Execute templates (create new project)	✎	✎	✎	◎	🔧
Modify existing templates	✕	✕	✎	✕	🔧

Create new templates	✕	✕	✎	✕	🔧
CI/CD & PIPELINES					
View all pipelines and history	👁	👁	👁	👁	🔧
Trigger Dev environment deployments	✎	✎	👁	✎	🔧
Trigger QA/Staging deployments	✎*	✎	👁	✎	🔧
Trigger Production deployments	✕	✕	✕	✎	🔧
Modify pipeline configurations	✕	✕	🔧	✎	🔧
MULESOFT CLOUDHUB					
View CloudHub (Dev/QA envs)	👁	👁	👁	👁	🔧
View CloudHub (Production env)	👁	👁	👁	👁	🔧
Deploy to Dev/QA CloudHub	✎*	✎	✕	✎	🔧
Deploy to Production CloudHub	✕	✕	✕	✎	🔧
Manage Anypoint configurations	✕	✕	✕	✎	🔧
SECURITY & COMPLIANCE					
View scan results — own team (SonarQube/Veracode)	👁	👁	👁	👁	🔧
View scan results — all teams	✕	👁	👁	👁	🔧
View audit logs	✕	✕	🔧	👁	🔧
Export compliance reports	✕	✕	🔧	✕	🔧
PLATFORM ADMINISTRATION					
Manage Backstage plugins	✕	✕	🔧	✕	🔧
Configure SSO / authentication	✕	✕	🔧	✕	🔧
Manage user roles and permissions	✕	✕	🔧	✕	🔧
Platform-level configurations	✕	✕	🔧	✕	🔧
SERVICENOW INTEGRATION					
View incidents and change requests	👁	👁	👁	👁	🔧
Create incidents / raise tickets	✎	✎	✎	✎	🔧
Link incidents to deployments	✕	✎	✎	✎	🔧
API Scorecards / Metrics — view	👁	👁	👁	👁	🔧

Role Specifications

This section provides detailed specifications for each role, including scope boundaries and capabilities.

Developer

Scope:
Default role for all MuleSoft API developers providing full self-service capability for day-to-day development work within team boundaries.

Primary Capabilities:

- Full catalog visibility across all teams (read-only for other teams' resources)
- Create and manage catalog entries for own team's APIs and services
- Execute scaffolder templates to create new API projects
- Deploy to Dev and QA environments for own team's APIs
- Publish and update Docusaurus for own team
- View CI/CD pipeline status and deployment history
- Create ServiceNow incidents

Boundaries:

- Cannot deploy to Staging or Production environments
- Cannot modify scaffolder templates or platform configuration
- Cannot modify catalog entries owned by other teams
- Cannot view security scan results for other teams
- No access to Anypoint Platform configuration
- No access to audit logs or compliance reports

Tech Lead

Scope:
Extended permissions for senior engineers and team technical leads who need broader visibility and team-level resource management.

Primary Capabilities:

- All Developer permissions
- Modify any catalog entry owned by their team (not just their own entries)
- Trigger Staging environment deployments for team's APIs
- View security scan results (SonarQube, Veracode) across all teams
- Link ServiceNow incidents to specific deployments
- Approve and manage team-level API documentation

Boundaries:

- Cannot deploy to Production environments
- Cannot modify scaffolder templates or platform configuration
- Cannot modify catalog entries owned by other teams
- No access to Anypoint Platform configuration
- No access to audit logs or platform administration

Key Distinction:
Tech Leads have cross-team visibility for security scans and broader team resource management, but still cannot touch production or platform configuration.

Platform Engineer

Scope:
Full control over Backstage platform itself - responsible for IDP configuration, template management, plugin integration, and team onboarding.

Primary Capabilities:

- Create, modify, and delete scaffolder templates
- Manage all Backstage plugins and integrations
- Configure SSO, authentication, and authorization policies
- Modify any catalog entry across all teams (for governance purposes)
- Onboard new teams and configure team structures
- Export compliance reports and access audit logs
- Manage Docusaurus platform configuration
- Configure integrations (SonarQube, Veracode, ServiceNow, CloudHub connector)

Boundaries:

- **Cannot deploy MuleSoft APIs to any environment** (Dev, QA, Staging, or Production)
- **Cannot manage Anypoint Platform configurations**
- Platform Engineers manage the IDP; they don't operate the workloads

Key Distinction:
Platform Engineers own Backstage configuration and templates. DevOps/SRE owns production deployments and runtime environments. Clear separation of duties - neither can do the other's job.

DevOps / SRE

Scope:
Full control over production environments, CI/CD pipelines, and MuleSoft CloudHub operations - the only non-Admin role that can deploy to production.

Primary Capabilities:

- **Deploy to Production CloudHub** (the defining permission)
- Deploy to all lower environments (Dev, QA, Staging)
- Manage CI/CD pipeline configurations across all teams
- Manage Anypoint Platform configurations and environment settings
- View all security scan results and audit logs
- Link ServiceNow change requests to production deployments
- View CloudHub application logs and health metrics across all environments

Boundaries:

- **Cannot modify Backstage platform configuration**
- **Cannot modify scaffolder templates**
- DevOps/SRE operates environments; they don't configure the platform

Production Deployment Requirements:

- All production deployments require an approved ServiceNow change request
- Deployment must be linked to the change request in ServiceNow
- Automatic audit event generated for every production deployment

Key Distinction:
DevOps/SRE owns runtime environments and deployments. Platform Engineers own Backstage configuration. Neither can do the other's job - separation of duties enforced.

Admin

Scope:
Break-glass emergency access with full unrestricted access to all Backstage features, all environments, and all configurations.

Primary Capabilities:

- Everything across all roles
- Modify user roles and permission policies
- Override any access restriction
- Direct database/backend access if needed
- Emergency platform recovery operations

Boundaries:

- **Should not be used for routine operations**
- All actions are logged and reviewed
- Maximum 2 people should hold this role
- Requires dual approval for activation (except P1 incidents)

Break-Glass Activation Process:

1. ServiceNow incident created documenting reason for activation
2. Dual acknowledgment required (activator + manager, or on-call security contact)
3. All actions during activation window logged to audit trail
4. Maximum 4-hour activation window
5. Access revoked immediately when incident resolved
6. Post-incident review completed within 48 hours

Typical Use Cases:

- Backstage platform outage requiring manual recovery
- SSO/authentication system failure blocking normal access
- Critical security incident requiring immediate permission changes
- Data corruption requiring direct database intervention

Role Assignment Decision Matrix

Scenario	Recommended Role
MuleSoft developer building APIs	**Developer**
Senior engineer leading a team	**Tech Lead**
Need to review security scans across teams	**Tech Lead**
Manage Backstage templates and plugins	**Platform Engineer**
Configure SSO or permission policies	**Platform Engineer**
Deploy to production CloudHub	**DevOps/SRE**
Manage Anypoint Platform configs	**DevOps/SRE**
Emergency platform recovery	**Admin**
Need both platform config AND prod deploy	**Two separate people** (separation of duties)